



Septiembre 2026

Actividad 1

Análisis y planificación del Pentest

Julieth Linares

Hacker Woman Council • **Ethical Hacking**

Objetivo del Pentest

Como parte de la evolución tecnológica de Aurora Market y su transición hacia una arquitectura de comercio electrónico centralizada, la organización ha identificado la necesidad de auditar su postura de seguridad tras un incidente operativo relacionado con la integridad y segregación de datos entre cuentas de usuario. Ante la imposibilidad de tipificar internamente la causa raíz (ya sea un fallo de control de acceso, una desviación en la configuración o una vulnerabilidad a nivel de aplicación), la presente propuesta de servicios de evaluación de seguridad tiene como propósito fundamental auditar los mecanismos de control y dotar a la alta dirección de un diagnóstico técnico certero. A continuación, se detallan los objetivos estratégicos definidos para el desarrollo de la auditoría:

- **Determinar el origen del incidente de fuga de datos y validar los controles de acceso (IAM).** Investigar técnicamente el reporte previo de un usuario que visualizó información confidencial ajena en su cuenta, auditando los flujos de autenticación, la gestión de sesiones y los controles de autorización (Access Control) mediante la metodología de la guía OWASP WSTG para esclarecer si se debió a un fallo lógico, una configuración no adecuada o una vulnerabilidad explotable.
- **Evaluar la exposición de la información sensible de los clientes (PII) bajo el marco CVSS.** Analizar bajo una modalidad de caja gris y con privilegios acotados el impacto y la explotabilidad asociados al acceso no autorizado de activos críticos almacenados en el e-commerce (nombres, correos, teléfonos, direcciones e historial de transacciones) que podría comprometer un atacante externo.
- **Medir la postura defensiva y la resiliencia de la plataforma:** verificar el cumplimiento de los controles de seguridad de la aplicación contrastándolos con el estándar OWASP ASVS, identificando debilidades arquitectónicas y vectores de explotación comunes antes de que el negocio continúe escalando operacionalmente.

Alcance

Se evaluará:

- **La aplicación web centralizada de Aurora Market:** Análisis exhaustivo de la interfaz principal de comercio electrónico accesible por los usuarios para la consulta y adquisición de productos tecnológicos.
- **Mecanismos de autenticación y gestión de sesiones:** Verificación de los flujos de registro, inicio de sesión y persistencia de sesión de los usuarios dentro de la plataforma.
- **Controles de autorización y segregación de privilegios (Access Control):** Auditoría de los permisos lógicos orientada a prevenir fallas que permitan la visualización cruzas de información entre cuentas distintas.
- **Módulos de transacciones y gestión de pedidos:** Revisión de los componentes encargados del flujo de compra y del historial transaccional de los clientes.
- **Panel de administración interno:** Evaluación de los accesos y funciones asignados al personal de la empresa para la gestión de productos, usuarios y pedidos.

Fuera del alcance

- Redes sociales corporativasanales de difusión externa y perfiles comerciales de Aurora Market donde se originó el negocio inicialmente.
- Infraestructura de correo electrónico (cuentas de correo y servidores de mensajería utilizados por la compañía)
- **Dispositivos y equipos personales de los empleados:** Computadores, teléfonos inteligentes o terminales de uso privado del personal interno.
- **Sistemas de proveedores externos:** Plataformas, pasarelas o servicios tecnológicos operados por terceros ajenos al núcleo de la aplicación web.
- **Pruebas de denegación de servicio (DoS / DDoS):** Quedan prohibidos los tests de estrés masivo que busquen saturar la disponibilidad operativa de la plataforma.

Autorización y condiciones

Permisos requeridos

- Autorización formal y por escrito otorgada por la dirección de Aurora Market para la ejecución de la auditoría sobre la infraestructura web.
- Credenciales de acceso de prueba (con privilegios de usuario estándar) para evaluar la navegación, la gestión de sesiones y la integridad de los datos de forma controlada.
- Aceptación de los límites operativos bajo el esquema de caja gris estipulado para la evaluación.

Condiciones acordadas

- Las pruebas técnicas se realizarán estrictamente en horarios de menor actividad para minimizar cualquier impacto en la operación del negocio.
- Quedan prohibidas las acciones que interrumpen deliberadamente el funcionamiento de la plataforma o comprometan la integridad de la información real de los clientes.
- Mantenimiento de una comunicación transparente, basada en colaboración y canales de contacto directo durante todo el proceso de evaluación.

Tipo de Pentest



Gray-Box Pentest

El servicio propuesto se ejecutará bajo la modalidad de Gray-box (Caja gris), empleando conocimiento parcial y accesos acotados para simular el perfil de riesgo de Aurora Marke debido a la ausencia de documentación técnica o código fuente, permitiendo auditar la aplicación web, bases de datos y esquemas de autenticación bajo opacidad controlada para detectar brechas de acceso sin requerir acceso interno total.

Planificación

- **Objetivos:** Auditar la plataforma web centralizada de Aurora Market para determinar el origen del incidente de fuga de datos entre cuentas, evaluar los controles de acceso y cuantificar la exposición de la información sensible de los clientes.
- **Alcance:** Delimitar la evaluación exclusivamente al ecosistema web del e-commerce (módulos de autenticación, gestión de carritos y panel administrativo) y al perímetro internet-facing para mapear los puntos de exposición hacia la red pública, excluyendo las redes sociales corporativas y las cuentas de correo electrónico.
- **Permisos y condiciones:** Requerir una carta de autorización formal de la directiva y establecer el uso obligatorio de cuentas de prueba con privilegios acotados y segregados, ejecutando las pruebas en horarios de bajo tráfico para salvaguardar la disponibilidad del negocio.
- **Metodología a utilizar:** OWASP Top 10 para la identificación de vulnerabilidades críticas y la guía OWASP WSTG para auditar flujos de sesión y contrastar los controles contra el estándar OWASP ASVS.
- **Recopilación de información previa:** Recolectar los endpoints públicos del e-commerce, los formularios de registro, los parámetros de las peticiones HTTP que gestionan las cuentas de usuario y los roles visibles, operando bajo la modalidad de caja gris sin acceso al código fuente.
- **Recursos necesarios:** Desplegar herramientas especializadas de reconocimiento externo como **Amass** o **Sublist3r** para mapear el perímetro internet-facing y **Nmap** para escanear los puertos y servicios expuestos, **Burp Suite Professional** para interceptar y modificar peticiones HTTP/HTTP y utilizar **OWASP ZAP** para ejecutar escaneos dinámicos de vulnerabilidades web.
- **Programación del pentest:** Calendarizar las ventanas de ejecución técnica en coordinación directa con la administración de Aurora Market.

Fases del Pentest



Reconocimiento

Mapear el perímetro internet-facing de Aurora Market y la superficie web pública mediante herramientas como Amass y Nmap, con el fin de identificar subdominios expuestos, puertos activos, rutas de inicio de sesión y formularios de usuario bajo un enfoque de caja gris.



Análisis de Vulnerabilidades

Inspeccionar los flujos de autenticación, la gestión de sesiones y los controles de autorización utilizando la guía OWASP WSTG y el OWASP Top 10, buscando específicamente fallas de control de acceso roto (Broken Access Control) que expliquen la fuga de datos entre cuentas.



Explotación

Emplear Burp Suite Professional para manipular parámetros HTTP y comprobar si es posible visualizar información personal (PII) de otros usuarios.



Post-explotación

Analizar el alcance del impacto para determinar si una cuenta regular puede escalar privilegios hacia el panel administrativo.



Informe

Entregar un reporte técnico y ejecutivo con la clasificación de riesgos CVSS y las directrices de mitigación para la directiva.

Investigación

Metodología a implementar: OWASP
(Open Web Application Security Project)



¿POR QUÉ SERÍA ÚTIL PARA ESTE PROYECTO? Debido a que permite atacar directamente la causa raíz de la fuga de datos en Aurora Market mediante el uso de su marco técnico especializado en seguridad web, considerando que su implementación es clave para auditar los flujos de inicio de sesión y el control de acceso, asegurando que las cuentas de los usuarios mantengan una segregación estricta basada en roles (RBAC) y que la información personal (PII) de los clientes no se filtre entre perfiles.